

Threat model report for Jankowski_CSD370

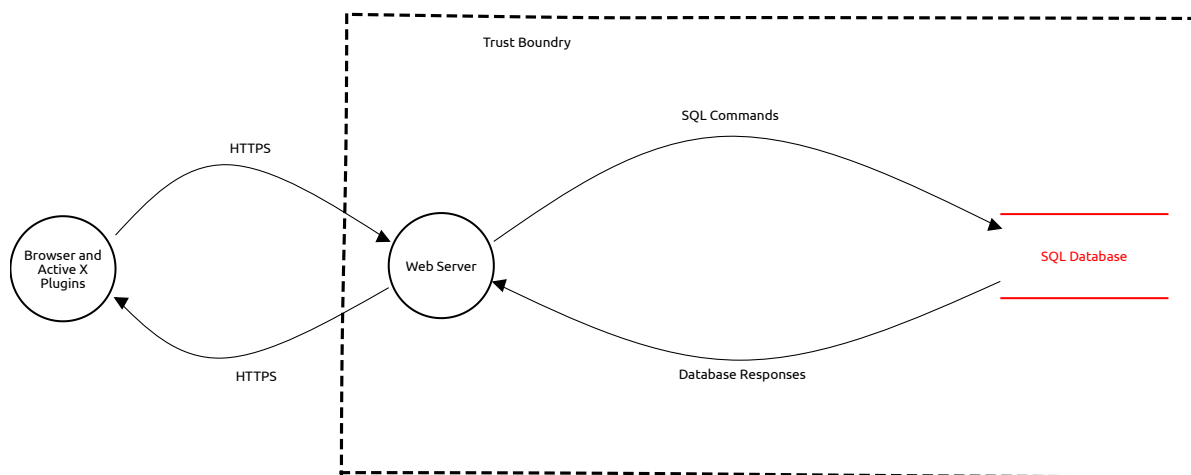
Owner:

Max Jankowski

Reviewer:**Contributors:**

Sue Sampson

High level system description



Browser and Active X Plugins (Process)

Description:

No threats listed.

Web Server (Process)

Description:

No threats listed.

SQL Database (Data Store)

Description:

SQL injection from unsanitized input

Tampering, Mitigated, Low Priority

Description:

A bad actor sends a malicious SQL syntax from a user facing input. If the server passes this data (unsanitized) to the database, the attacker can then manipulate to modify, read and delete information.

Mitigation:

Use parameterized queries, and apply allowlist input validation layer to the web server before any data reaches the database layer. As always principle of least privilege.

https://owasp.org/www-community/attacks/SQL_Injection

Data exposure from excess database permissions

Information disclosure, Open, Medium Priority

Description:

Pretty straight forward, should the server database account permissions be too broad, a compromised server process may expose some sensitive data.

Mitigation:

You can never go wrong with going with the principle of least privilege, particularly when working with database accounts.

DDOS attack from Query flooding

Denial of service, Open, High Priority

Description:

the attacker has gained access to the SQL command data flow, or is actively exploiting our web server layer. they are issuing a large volume of tasking queries on our SQL server. This is exhausting the connection pool and server CPUs. This is making our database unavailable for legitimate users and work

Mitigation:

We recommend that we include query rate limiting at the web server level, connection pooling of the database with hard caps and execution limits of queries.

<https://www.youtube.com/watch?v=BhvnGJaZCG4>

HTTPS (Data Flow)

Description:

No threats listed.

HTTPS (Data Flow)

Description:

No threats listed.

SQL Commands (Data Flow)

Description:

No threats listed.

Database Responses (Data Flow)

Description:

No threats listed.